

Security & Governance Policies — Counsel Brief

⚠ **NOT LEGAL ADVICE.** An inventor-prepared brief requesting four operational governance policies counsel should produce. These are internal/operational policies (distinct from consumer-facing terms) that regulators, insurers, enterprise partners, and app stores increasingly expect a data-handling platform to have. Prepared 2026-09-14. See [DATA-IN-TRANSIT-SECURITY-POSTURE-COUNSEL-NOTE](#) , [DATA-COLLECTION-BRIEF-FOR-COUNSEL](#) .

Why this matters

The platform holds sensitive data (TINs, voice, behavioral) and moves real money. When something goes wrong — a breach, a reported vulnerability, a subpoena, a litigation hold — the company needs a written procedure decided *in advance*, not improvised. Several of these are also prerequisites for cyber insurance and for state breach-notification compliance.

The four policies counsel should produce

- **1) Incident-Response & Breach-Notification Plan** — roles, severity triage, containment steps, and the **state/federal/GDPR notification timelines and templates** (who is notified, how fast, by whom). Ties to the cyber-insurance coverage and the data-in-transit posture.
- **2) Vulnerability-Disclosure / Bug-Bounty Policy** — a safe-harbor channel for good-faith security reports, scope, and no-legal-action terms for compliant researchers (reduces the risk of an unmanaged public 0-day).
- **3) Records-Retention & Legal-Hold Policy** — how long each record class is kept and when it is destroyed (aligns with the privacy retention schedule and the biometric-destruction timeline), plus a **litigation-hold** procedure that suspends deletion when a claim is reasonably anticipated.
- **4) Law-Enforcement / Subpoena Response & Emergency-Disclosure Policy** — how the company responds to legal process and to emergency safety requests (relevant to Buddy Chat member-safety incidents), what it will/won't disclose, and member notice where lawful.

Decisions for counsel

Notification thresholds and timelines per launch jurisdiction; whether to run a formal bug-bounty vs. a private disclosure channel at launch; retention periods per record class; the standard for honoring emergency-disclosure requests; who inside the company owns each policy.

Not legal advice. Related: [INSURANCE-COVERAGE-BRIEF](#) , [DATA-PROCESSING-AND-SUBPROCESSOR-BRIEF](#) , [BIOMETRIC-CONSENT-AND-DATA-POLICY-BRIEF](#) , [GLOBAL-LAUNCH-LEGAL-STRATEGY-BRIEF](#) .